

GUIDE



Security aspects – Guidelines for their inclusion in publications



THIS PUBLICATION IS COPYRIGHT PROTECTED

Copyright © 2018 IEC, Geneva, Switzerland

All rights reserved. Unless otherwise specified, no part of this publication may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm, without permission in writing from either IEC or IEC's member National Committee in the country of the requester. If you have any questions about IEC copyright or have an enquiry about obtaining additional rights to this publication, please contact the address below or your local IEC member National Committee for further information.

IEC Central Office
3, rue de Varembe
CH-1211 Geneva 20
Switzerland

Tel.: +41 22 919 02 11
info@iec.ch
www.iec.ch

About the IEC

The International Electrotechnical Commission (IEC) is the leading global organization that prepares and publishes International Standards for all electrical, electronic and related technologies.

About IEC publications

The technical content of IEC publications is kept under constant review by the IEC. Please make sure that you have the latest edition, a corrigenda or an amendment might have been published.

IEC Catalogue - webstore.iec.ch/catalogue

The stand-alone application for consulting the entire bibliographical information on IEC International Standards, Technical Specifications, Technical Reports and other documents. Available for PC, Mac OS, Android Tablets and iPad.

IEC publications search - webstore.iec.ch/advsearchform

The advanced search enables to find IEC publications by a variety of criteria (reference number, text, technical committee,...). It also gives information on projects, replaced and withdrawn publications.

IEC Just Published - webstore.iec.ch/justpublished

Stay up to date on all new IEC publications. Just Published details all new publications released. Available online and also once a month by email.

Electropedia - www.electropedia.org

The world's leading online dictionary of electronic and electrical terms containing 21 000 terms and definitions in English and French, with equivalent terms in 16 additional languages. Also known as the International Electrotechnical Vocabulary (IEV) online.

IEC Glossary - std.iec.ch/glossary

67 000 electrotechnical terminology entries in English and French extracted from the Terms and Definitions clause of IEC publications issued since 2002. Some entries have been collected from earlier publications of IEC TC 37, 77, 86 and CISPR.

IEC Customer Service Centre - webstore.iec.ch/csc

If you wish to give us your feedback on this publication or need further assistance, please contact the Customer Service Centre: sales@iec.ch.

GUIDE



Security aspects – Guidelines for their inclusion in publications

INTERNATIONAL
ELECTROTECHNICAL
COMMISSION

ICS 35.030

ISBN 978-2-8322-5827-9

Warning! Make sure that you obtained this publication from an authorized distributor.

CONTENTS

FOREWORD.....	4
INTRODUCTION.....	6
1 Scope.....	7
2 Normative references	7
3 Terms and definitions	7
4 Guide to terminology	9
4.1 General.....	9
4.2 Primary recommended sources	10
4.3 Other relevant sources.....	10
4.3.1 General	10
4.3.2 Other application-domain independent sources.....	10
4.3.3 Other application-domain specific sources	10
5 Categorisation of publications.....	11
5.1 Overview.....	11
5.2 Publication type	11
5.2.1 General	11
5.2.2 Base security publications	12
5.2.3 Group security publications	12
5.2.4 Product security publications	13
5.2.5 Guidance security publications	13
5.2.6 Test security publications	13
5.2.7 Relationship between types of security publications.....	13
5.3 Application domain.....	13
5.4 Content.....	14
5.5 User/target group.....	14
5.6 Developing security publications	14
5.6.1 Base security publications	14
5.6.2 Group security publications	15
5.6.3 Product security publications	15
5.6.4 Guidance security publications and test security publications	15
6 Mapping/overview of publications	16
6.1 General.....	16
6.2 List of relevant publications.....	16
6.3 Domain table chart.....	16
7 Considerations for publications development	17
7.1 Practical considerations for publication writers.....	17
7.2 Development process of security in publications	17
7.3 Interrelation between functional safety and security	20
7.4 Specific requirements	21
7.4.1 Relationship with base security publications	21
7.4.2 Consider conformity assessment when writing standards.....	21
7.4.3 Lifecycle approach.....	22
7.4.4 Holistic system view	22
7.4.5 Vulnerability handling	23
7.4.6 Defence-in-depth	23
7.4.7 Security management	23

7.4.8	Supply chain.....	23
7.4.9	Consider greenfield and brownfield.....	24
7.4.10	Use of term integrity	24
7.5	Security risk assessment	24
7.5.1	General	24
7.5.2	Iterative process of security risk assessment and risk mitigation.....	25
7.5.3	Maintaining safe operation.....	25
7.5.4	Scenario analysis	26
7.5.5	Security risk mitigation strategy	26
7.5.6	Validation	26
	Bibliography.....	27
	Figure 1 – Possible categorization of publications.....	11
	Figure 2 – Types of publications	12
	Figure 3 – Publications and application domains.....	16
	Figure 4 – Example of security requirements, threats, and possible attacks	17
	Figure 5 – Decision flow chart.....	19
	Figure 6 – Interrelation between functional safety and security	20
	Figure 7 – Example of security management cycle for an organization.....	22
	Figure 8 – Selected measures for defence-in-depth strategy.....	23
	Figure 9 – Possible impact of security risk(s) on the safety-related control system.....	25

INTERNATIONAL ELECTROTECHNICAL COMMISSION

**SECURITY ASPECTS – GUIDELINES FOR
THEIR INCLUSION IN PUBLICATIONS**

FOREWORD

- 1) The International Electrotechnical Commission (IEC) is a worldwide organization for standardization comprising all national electrotechnical committees (IEC National Committees). The object of IEC is to promote international co-operation on all questions concerning standardization in the electrical and electronic fields. To this end and in addition to other activities, IEC publishes International Standards, Technical Specifications, Technical Reports, Publicly Available Specifications (PAS) and Guides (hereafter referred to as “IEC Publication(s)”). Their preparation is entrusted to technical committees; any IEC National Committee interested in the subject dealt with may participate in this preparatory work. International, governmental and non-governmental organizations liaising with the IEC also participate in this preparation. IEC collaborates closely with the International Organization for Standardization (ISO) in accordance with conditions determined by agreement between the two organizations.
- 2) The formal decisions or agreements of IEC on technical matters express, as nearly as possible, an international consensus of opinion on the relevant subjects since each technical committee has representation from all interested IEC National Committees.
- 3) IEC Publications have the form of recommendations for international use and are accepted by IEC National Committees in that sense. While all reasonable efforts are made to ensure that the technical content of IEC Publications is accurate, IEC cannot be held responsible for the way in which they are used or for any misinterpretation by any end user.
- 4) In order to promote international uniformity, IEC National Committees undertake to apply IEC Publications transparently to the maximum extent possible in their national and regional publications. Any divergence between any IEC Publication and the corresponding national or regional publication shall be clearly indicated in the latter.
- 5) IEC itself does not provide any attestation of conformity. Independent certification bodies provide conformity assessment services and, in some areas, access to IEC marks of conformity. IEC is not responsible for any services carried out by independent certification bodies.
- 6) All users should ensure that they have the latest edition of this publication.
- 7) No liability shall attach to IEC or its directors, employees, servants or agents including individual experts and members of its technical committees and IEC National Committees for any personal injury, property damage or other damage of any nature whatsoever, whether direct or indirect, or for costs (including legal fees) and expenses arising out of the publication, use of, or reliance upon, this IEC Publication or any other IEC Publications.
- 8) Attention is drawn to the Normative references cited in this publication. Use of the referenced publications is indispensable for the correct application of this publication.
- 9) Attention is drawn to the possibility that some of the elements of this IEC Publication may be the subject of patent rights. IEC shall not be held responsible for identifying any or all such patent rights.

This first edition of IEC Guide 120 has been prepared, in accordance with ISO/IEC Directives, Part 1, Annex A, by the Advisory Committee on Information security and data privacy (ACSEC). This is a non-mandatory guide in accordance with SMB Decision 136/8.

The text of this guide is based on the following documents:

DV	Report on voting
C/2086/DV	C/2113A/RV

Full information on the voting for the approval of this Guide can be found in the report on voting indicated in the above table.

This document has been drafted in accordance with the ISO/IEC Directives, Part 2.

A bilingual version of this publication may be issued at a later date.

IMPORTANT – The 'colour inside' logo on the cover page of this publication indicates that it contains colours which are considered to be useful for the correct understanding of its contents. Users should therefore print this document using a colour printer.

INTRODUCTION

The increasing complexity and connectivity of systems, products, processes and services entering the market requires that the consideration of security aspects be given a high priority. Inclusion of security aspects in standardization provides protection from and response to risks of unintentionally and intentionally caused events that can disrupt the functionality/operation of products and systems.

When preparing publications, committees should ensure that relevant resilience requirements applicable to their application domain are included. Security aspects will in many cases play a role in achieving resilience directed standards.

In this guide, the term “committee”, includes technical committees, subcommittees and system committees. The term “publication” includes “standard”, “technical report”, “technical specification” and “guide”.

National laws (legislation and regulation) may override the general application of publications.

NOTE Publications can deal exclusively with security aspects or can include clauses specific to security.

SECURITY ASPECTS – GUIDELINES FOR THEIR INCLUSION IN PUBLICATIONS

1 Scope

This document provides guidelines on the security topics to be covered in IEC publications, and aspects of how to implement them. These guidelines can be used as a checklist for the combination of publications used in implementation of systems.

This document includes what is often referred to as “cyber security”.

This document excludes non electrotechnical aspects of security such as societal security, except where they directly interact with electrotechnical security.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC Directives Part 2:2018, *Principles and rules for the structure and drafting of ISO and IEC documents*

3 Terms and definitions

For the purposes of this document, the following terms and definitions apply.

ISO and IEC maintain terminological databases for use in standardization at the following addresses:

- IEC Electropedia: available at <http://www.electropedia.org/>
- ISO Online browsing platform: available at <http://www.iso.org/obp>

3.1

accountability

property of a system (including all of its system resources) that ensures that the actions of a system entity may be traced uniquely to that entity, which can be held responsible for its actions

[SOURCE: IEC TS 62443-1-1:2009, 3.2.3]

3.2

attack

attempt to destroy, expose, alter, disable, steal or gain unauthorized access to or make unauthorized use of an asset

[SOURCE: ISO/IEC 27000:2016, 2.3]

3.3

authentication

provision of assurance that a claimed characteristic of an entity is correct

[SOURCE: ISO/IEC 27000:2016, 2.7]

3.4

authorization

right or permission that is granted to a system entity to access a system resource

[SOURCE: IEC TS 62443-1-1:2009, 3.2.14]

3.5

availability

property of being accessible and usable upon demand by an authorized entity

[SOURCE: ISO/IEC 27000:2016, 2.9]

3.6

confidentiality

property that information is not made available or disclosed to unauthorized individuals, entities, or processes

[SOURCE: ISO/IEC 24767-1:2008, 2.1.2]

3.7

functional safety

part of the overall safety that depends on functional and physical units operating correctly in response to their inputs

[SOURCE: IEC 60050-351:2013, 351-57-06]

3.8

harm

injury or damage to the health of people, or damage to property or the environment

[SOURCE: ISO/IEC GUIDE 51:2014, 3.1]

3.9

integrity

property of accuracy and completeness

[SOURCE: ISO/IEC 27000:2016, 2.40]

3.10

non-repudiation

ability to prove the occurrence of a claimed event or action and its originating entities

[SOURCE: ISO/IEC 27000:2016, 2.54]

3.11

risk

combination of the probability of occurrence of harm and the severity of that harm

Note 1 to entry: The probability of security risks often cannot be determined in the same way as the probability of safety hazards based on statistical analysis

[SOURCE: IEC 60050-351:2013, 351-57-03, modified – Note 1 to entry has been added]

3.12

safety

freedom from risk which is not tolerable

[SOURCE: ISO/IEC GUIDE 51:2014, 3.14]

3.13**security**

condition that results from the establishment and maintenance of protective measures that ensure a state of inviolability from hostile acts or influences

Note 1 to entry: Hostile acts or influences could be intentional or unintentional.

[SOURCE: IEC 62351-2:2008, modified – Note 1 to entry has been added]

3.14**security control**

measure (including process, policy, device, practice or other action) which modifies security risk or use

3.15**security service**

mechanism used to provide confidentiality, data integrity, authentication, or non-repudiation of information

[SOURCE: IEC TS 62443-1-1:2009, 3.2.115]

3.16**threat**

potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm

[SOURCE: IEC TS 62443-1-1:2009, 3.2.125]

3.17**vendor**

manufacturer or distributor of a product

[SOURCE: IEC 62337:2012, 3.12, modified – replaced “piece of equipment/instrument/package unit” with “product”]

3.18**vulnerability**

flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy

Note 1 to entry: This definition of vulnerability should not be confused with the term vulnerability when used in the context of general risk management, where it encompasses the notion of possibility of exposition to a risk.

[SOURCE: IEC TR 62918:2014, 3.16, modified – Note 1 to entry has been added]

4 Guide to terminology

4.1 General

There are already many security-related terms and definitions in existing publications. Therefore, before defining a new term, existing terms and definitions should be checked first. Primary recommended sources are shown in 4.2 and they should be used in preference to the other relevant sources shown in 4.3. If no appropriate term and definition is found in those sources, either modify an existing one or define a new one.

Definitions in this document are not intended to be generic ones but only apply to this document.

The ISO/IEC Directives Part 2:2018, Clause 16, defines how the terms and definitions in IEC publications are drafted.

NOTE The same term might have different definitions depending on the context in which it is used, or different terms might be used for the same or similar meaning in different application domains.

4.2 Primary recommended sources

The sources for this category are:

- 1) IEC 60050 (all parts) (IEV) [2]¹
- 2) IEC Glossary [3]
- 3) ISO/IEC JTC 1 SC 27 Standing Document SD6, Glossary of IT Security Terminology [4]

where IEC 60050 and the IEC Glossary should be used in preference.

IEC 60050 provides representative definitions to more than 20 000 terms, organized by subject areas in IEC. The IEC Glossary is a compilation of electrotechnical terms extracted from the “Terms and definitions” clause in existing IEC publications.

If no appropriate term or definition is found in the two sources above, ISO/IEC JTC 1 SC 27 SD6, which covers more security-related terms and definitions, should be consulted.

NOTE Application-domain specific terms developed by IEC committees are also considered to be primary sources. These can be searched using the web page of the IEC Glossary.

4.3 Other relevant sources

4.3.1 General

There are a variety of resources available which focus on certain application domains of electrotechnology such as energy, building, healthcare, and transportation.

This category includes application-domain independent sources (4.3.2) and application-domain specific sources (4.3.3).

4.3.2 Other application-domain independent sources

- IETF RFC 4949 [5]
- NISTIR 7298 [6]
- IEEE, Standards Glossary [7]
- ITU, ITU Terms and Definitions [8]

4.3.3 Other application-domain specific sources

- Healthcare: HL7, Glossary Of Acronyms, Abbreviations and Terms Related To Information Security In Healthcare Information Systems [9]
- Nuclear: IAEA, Nuclear Security Series Glossary [10]
- Energy: IEA, Glossary [11]

¹ Numbers in square brackets refer to the Bibliography.

5 Categorisation of publications

5.1 Overview

There are several different ways in which security publications can be categorised. Four possible aspects for the categorization are shown in Figure 1. Publications can belong to more than one category. Each category is identified by combination types of each aspect.

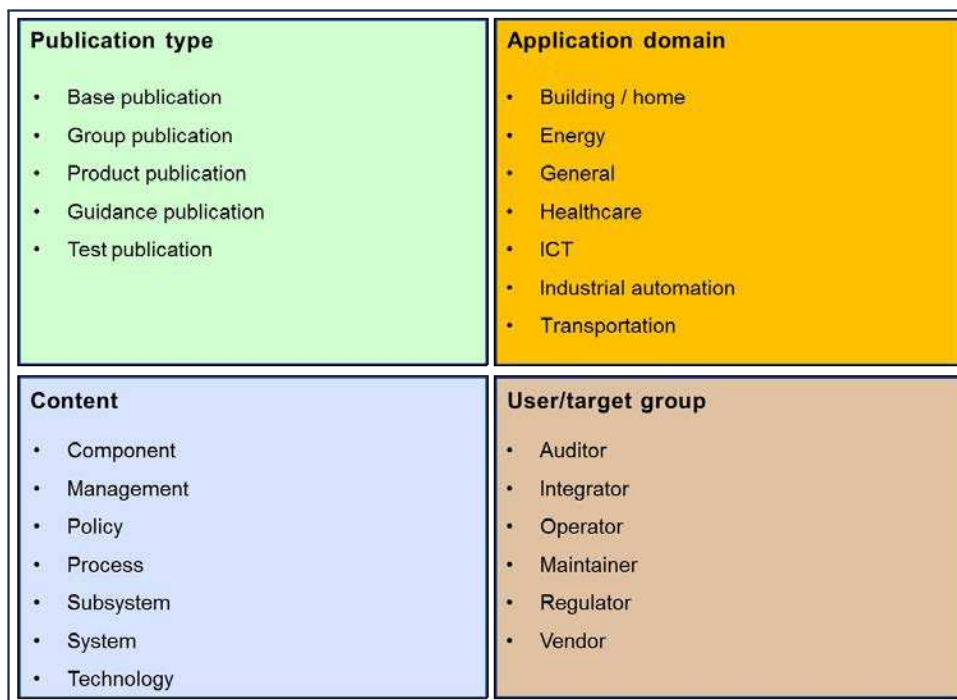


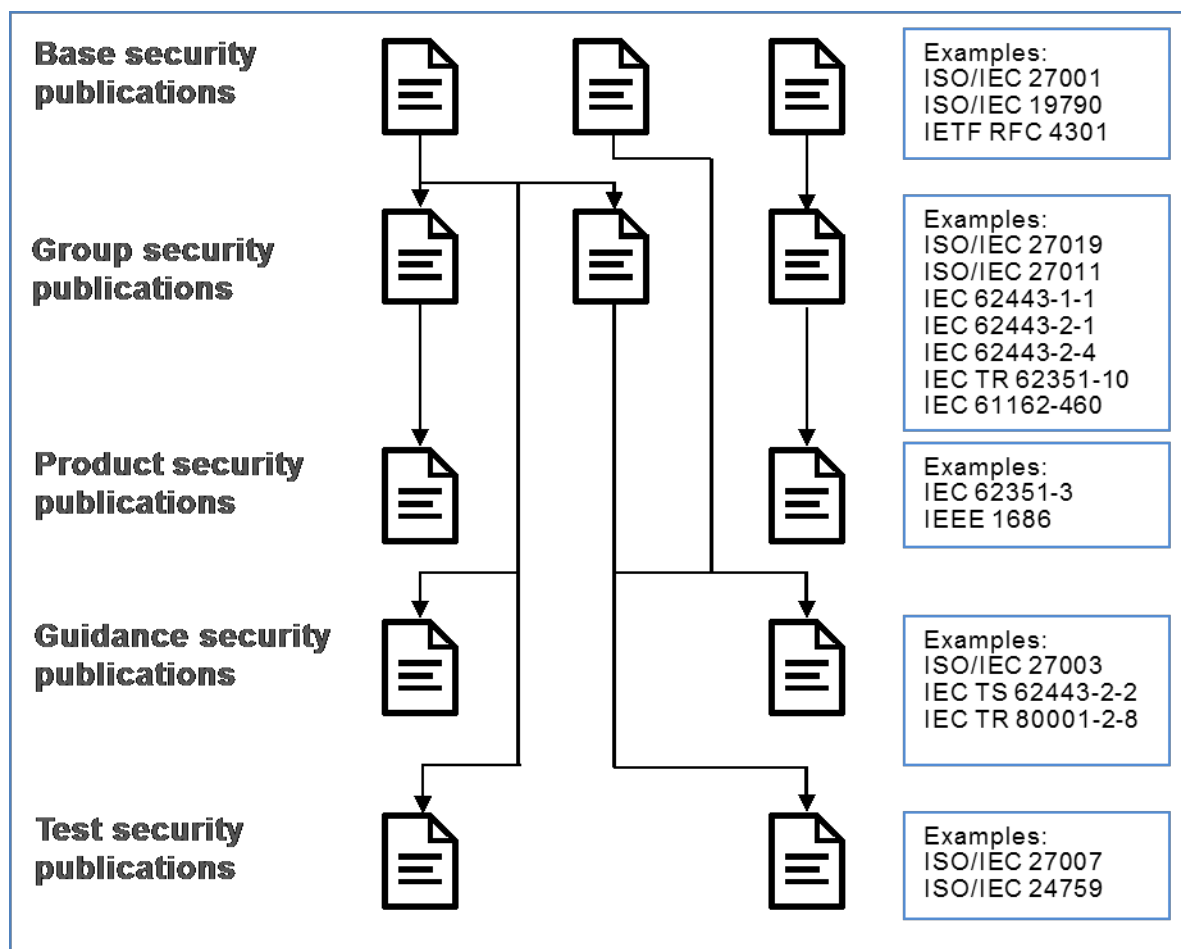
Figure 1 – Possible categorization of publications

5.2 Publication type

5.2.1 General

Publications for security can be categorised as one of the five types listed below, as shown in Figure 2:

- base security publication;
- group security publication;
- product security publication;
- guidance security publication;
- test security publication.



NOTE The examples listed in Figure 2 are not exhaustive.

Figure 2 – Types of publications

5.2.2 Base security publications

Base security publications are publications that define some aspect of security, in a generic manner.

Base security publications deal with fundamental concepts, principles and requirements with regard to general security aspects applicable to a wide range of products and systems. Horizontal standards dealing with security, as defined in IEC GUIDE 108 [14], are base security publications.

5.2.3 Group security publications

Group security publications show how to apply security in one of the application domains. To do this, they may reference or customise base security publications. They are equivalent to group publications as defined in IEC GUIDE 104 [13] for safety applications.

Group security publications may be applicable to many products or systems, or families of similar products or systems.

Group security publications are sometimes referred to as sector-specific security publications.

5.2.4 Product security publications

Product security publications define how to apply base security publications or group security publications for a particular type of product. They ensure that different products can interact or interoperate securely, and can be controlled and managed in a uniform manner.

Product security publications should as far as possible define their requirements by reference to base security publications and group security publications.

NOTE In this context, the term product includes items such as process, service, installation, and combinations thereof.

5.2.5 Guidance security publications

Guidance security publications should not contain requirements. They explain how to implement base publications, and group or product publications.

In some application areas, guidance publications are not used. Instead necessary guidance information is provided through informative annexes within the relevant requirements standard.

5.2.6 Test security publications

Test security publications define ways to determine that the requirements of base publications, and group or product publications have been correctly implemented.

Test publications typically have a specialised audience and often make reference to conformity assessment. They may define or identify reference implementations that can be used to determine correct implementation through successful interoperation.

5.2.7 Relationship between types of security publications

The relationship between these different types of publications is shown in Figure 2. There is an equivalent figure for safety publications in Annex B of IEC GUIDE 104:2010 [13].

5.3 Application domain

Publications for security can also be categorised according to their intended domain of application. This may be a sector of economic or industrial activity, a type of market, or an area of application.

Some examples of application domains are listed below, as shown in Figure 1:

- building/home;
- energy;
- general;
- healthcare;
- ICT;
- industrial automation;
- transportation.

In many cases an application domain will have an associated IEC committee responsible for the development of publications for that domain. This committee should accept responsibility for the development of the associated security publications.

Such committees will normally be able to define relevant threat models and security use cases independently, but may need to seek advice from the committees responsible for base security publications in configuring or customising those base security publications when referenced.

5.4 Content

Publications for security can also be grouped by their type of content.

Some examples of possible groups are listed below, as shown in Figure 1:

- component;
- management;
- policy (not in IEC);
- process;
- subsystem;
- system;
- technology.

For example, electrotechnical standards for information security management include the generic standard ISO/IEC 27001 [15] (developed by JTC 1/SC 27), but also the sector-specific standards ISO/IEC 27019 [16] (developed by JTC 1/SC 27), IEC 62443-2-1 [17] (developed by TC 65) and IEC 62645 [18] (developed by SC 45A).

5.5 User/target group

Publications for security can also be grouped by their intended audience. Some examples of possible user groups are listed below, as shown in Figure 1:

- auditor;
- integrator;
- operator;
- maintainer;
- regulator;
- vendor.

5.6 Developing security publications

5.6.1 Base security publications

Many base security publications were originally developed by government, consortia or specialist commercial organizations. Most of these have been subsequently formalised into international or other generally accepted technological standards. IEC committees should reference the public form of these standards if one exists. The rules for referencing non ISO and IEC standards from within ISO and IEC publications are specified in 10.2 of ISO/IEC Directives Part 2:2018.

Within IEC, base security publications defining security controls are prepared by ISO/IEC JTC 1/SC 27, IT security techniques. Other IEC committees should not attempt to develop such generic security controls as they are unlikely to have the necessary level of generic security expertise and information. If an IEC committee identifies a need for a new publication of this type, it should supply the relevant use case to JTC 1/SC 27 and request it to prepare an appropriate publication.

It is left open to IEC committees to define security publications for their own domain to address:

- relevant terminology,
- common threats and attacks,
- security design philosophy or such related issues, and
- common technical requirements (such as interoperability).

5.6.2 Group security publications

Group security publications will normally be domain-specific publications.

Group security publications will normally be developed within one IEC committee, but may have application in areas beyond the scope of that committee. Normally, the domain committee will retain responsibility for publications development and maintenance, but should take account of other known use cases and requirements of wider use.

Group security publications should build upon basic security services as defined in appropriate base security publications, but may be parameterised or configured to reflect the intended field of application. This includes identifying specific threats, types of attack and consequences that apply to the intended field of application.

IEC committees should not attempt to restrict the applicability of group security publications without good reason. This will enable developers of compliant products and systems to offer them for use elsewhere. However, group security publications should clearly identify any assumptions or limitations concerning their applicability in order to minimise the potential for misuse.

Where necessary, IEC committees developing group security publications should consult or work collaboratively with the originators of the base security publications that they reference.

5.6.3 Product security publications

Product security publications should normally be produced by the IEC committee that deals with the aspects of that type of product or series of products. Product security publications will often only deal with the product's interaction with its environment, referencing generic base or group publications to define internal behaviour.

5.6.4 Guidance security publications and test security publications

These publications should be produced by the IEC committee responsible for the base, group or product publication to which these publications refer. Assistance should be sought from specialist committees dealing with conformity assessment if applicable.

Committees should consider whether it is more effective to deal with guidance and test aspects of a publication through body text or annexes to the main specification, rather than by separate publications or parts of publications. There are benefits and drawbacks in both approaches.

Committees referencing guidance publications or annexes should take care not to create normative references to guidance information. In normative publications, references to guidance information should appear in the bibliography.

6 Mapping/overview of publications

6.1 General

ACSEC has developed and maintains up to date a set of files for use by IEC committees, in order to provide a global vision of the landscape of standardization in security.

These files are accessible from the Documents/Support Documents webpage from the ACSEC dashboard on the IEC website, see [1].

ACSEC invites all IEC committees developing, revising or withdrawing publications involving security aspects or requirements to notify ACSEC so that these files can be updated.

6.2 List of relevant publications

The list of publications provides useful information for each identified publication:

- committee;
- publication reference;
- publication title;
- security relevance;
- type of publication, see 5.2;
- application domain, see 5.3;
- content, see 5.4;
- user/target group, see 5.5;
- link to the IEC webstore.

This list will help publication writers in identifying existing publications, in order to avoid duplication of work and favour consistency and coherence.

6.3 Domain table chart

Figure 3 illustrates the principle of the application-domain table chart, which indicates in which application domains the publications produced by a body are applied or will be applied in the future. This will help publication users to identify committees and/or publications which could play a role in the dedicated application domain.

	Building automation	Energy	Healthcare	Home automation	ICT	Industrial automation	Nuclear	Transportation
IEC TC X	a	a				m		
IEC TC Y	a	m	a	a	a	d	a	a
IEC TC Z	a		m	d				

m	main domain
a	further application
d	under development

Key:

Main domain: primary area of application for the publications of the committee.

Further application: secondary areas of application for the publications of the committee.

Under development: potential future areas of application for the publications of the committee.

Figure 3 – Publications and application domains

7 Considerations for publications development

7.1 Practical considerations for publication writers

IEC publications should be clear, concise, consistent and complete, and should be written in line with ISO/IEC Directives Part 2. Publication writers should have in mind that security of systems relies on security risk assessment and management. Therefore, security considerations in publications should sometimes be formulated as recommendations to allow the applicability of the security considerations to different systems belonging to the scope of the publication. For example, interoperability between systems can require that product security publications specify requirements instead of recommendations.

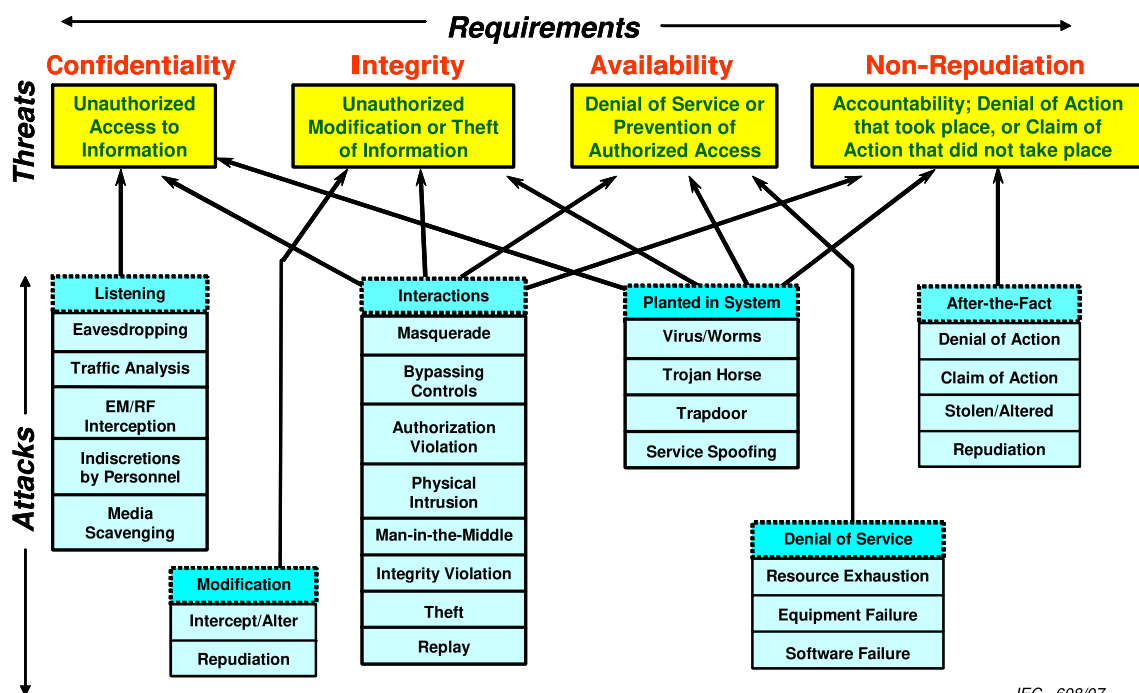
Moreover, security considerations in publications should not specify any particular or commercial solution to address requirements, but should adopt a generic approach to provide security recommendations.

Where appropriate, security considerations should be included in specific clauses in the IEC publication.

Security research and technology is developing rapidly; as a result any publication should be reviewed on a regular basis to ensure that it is current with technology and threat landscape.

7.2 Development process of security in publications

Figure 4 gives an example of the relationships between security requirements, threats, and attacks.



IEC 608/07

NOTE Figure 4 is taken from IEC TS 62351-1:2007, Figure 1.

Figure 4 – Example of security requirements, threats, and possible attacks

ACSEC recommends that:

- security issues be considered from the start of the publication development process. It should be checked, whether security is to be considered (see Figure 5) in terms of mandatory requirements or recommendations;
- security considerations (including acceptable risk if appropriate) be addressed by a risk based approach (see ISO 31000 [34] as a generic approach);

NOTE Risk based approach does not imply risk assessment.

- if security aspects to be addressed in the publication have been identified, it should be determined whether existing publications can be referenced (see 6.2). If no suitable publication exists, the identified security provisions should be developed.

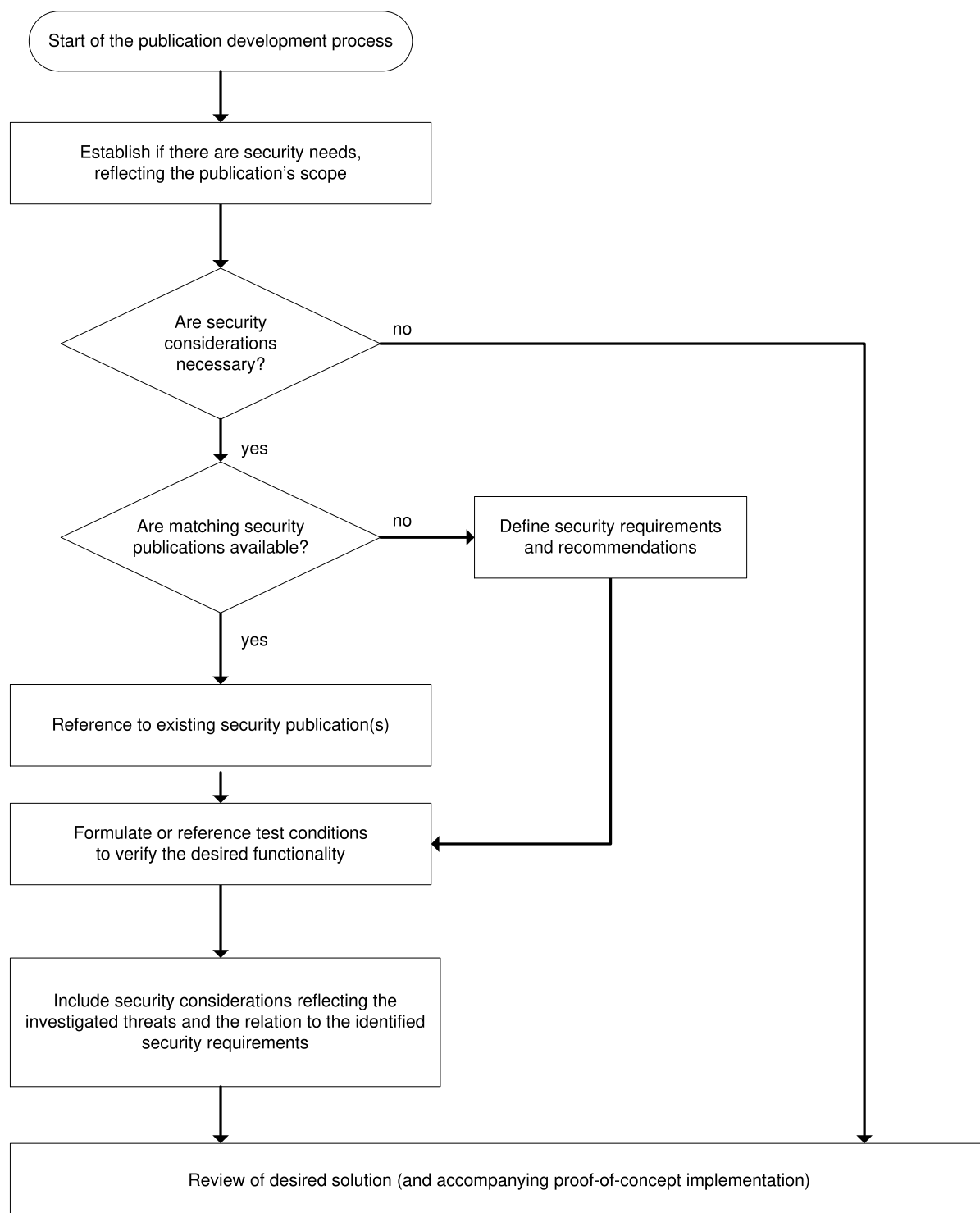


Figure 5 – Decision flow chart

The guidelines listed below elaborate the flow chart and provide further recommendations for covering security considerations in publications as appropriate (partly from IEC TS 62351-1 [19]).

- 1) Consider the relevance of security aspects to the subject of the publication and identify the security needs.
- 2) If no specific considerations are necessary for the publication, consider documenting the rationale. If specific considerations are required, do not re-invent requirements or solutions if they can be found in well-established publications. Instead, use normative

references to publications as much as possible, with the selection of alternatives or options normatively stated.

- 3) If existing publications do not provide a solution to the identified threats and risks, additional security requirements and/or recommendations should be defined.
- 4) To ensure that the specified security measures address the identified threats, formulate or reference test conditions that can help the user of the publication to verify the desired functionality. Therefore it is recommended that a well described set of tools and documentation methods be set in place. These will assist in conformity assessment, see 7.4.2.
- 5) Include security considerations reflecting the investigated threats and the relation to the identified security requirements

7.3 Interrelation between functional safety and security

Security is expected to protect functional safety, for example from interference or unauthorized modification.

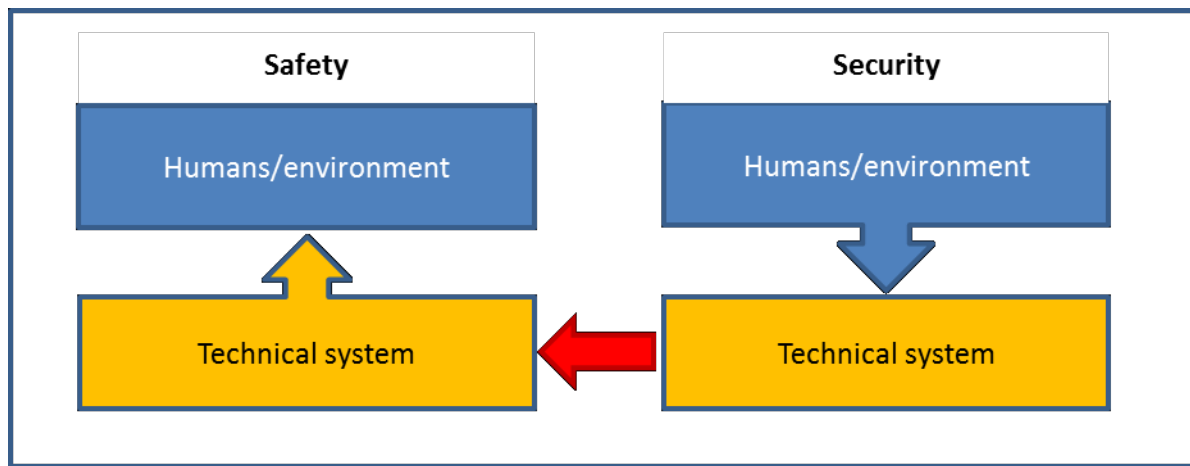


Figure 6 – Interrelation between functional safety and security

In Figure 6, there is an inverse direction of impact when safety and security aspects are compared. In functional safety, humans and the environment are potentially harmed by failure of the technical system. For security, the technical system is the potentially harmed target of disturbance by intended or accidental attacks carried out by humans or originating from the environment. The security of a technical system might impact safety, and loop back to harm humans, property or the environment. The increase of connected components and systems is not only increasing the complexity of this “system of systems” but also raises concerns with respect to the safety impact due to security issues.

To ensure proper security and safety features are implemented in the system, both safety and security risk analysis should be performed.

Safety and security sometimes have conflicting requirements. For instance information on a system is expected to be protected from access by anyone who cannot authenticate themselves to the system, but for safety reasons a break-glass function is required. For medical equipment, this is to allow access to the system and data in emergency cases where authentication is not possible when for instance domain servers are down or when emergency medical staff do not have the credentials to access the medical system but require immediate access to treat a patient.

Principles for interrelation between security and functional safety are:

- security controls should not affect functional safety (e.g. no change of existing proof of functional safety);

- in particular, security controls should not affect the performance of functional safety measures beyond an acceptable level (e.g. integrity of data relevant for functional safety);
- functional safety measures should be designed in a way that they are reasonably protected from failures of security controls (e.g. update of vulnerable software without re-validation);
- in particular, security controls should mitigate identified hazards caused by security threats in order to achieve the requested level of safety. See also 7.5.3.

Security and safety risk assessments can assist in determining where the two fields conflict and which requirements prevail. A security risk assessment can also assist in determining if a threat could be a potential cause for a hazard. It is valuable to have safety experts joining a security risk assessment. Safety lifecycle management is often reasonably stable as it is driven by the discovery of failures while security lifecycle management requires continuous updates and changes to the system to mitigate new vulnerabilities, threats and changes in the threat landscape. These security updates can have an impact on safety and as a result often require re-validation/certification of the system when the configuration has changed. Combination of activities addressing safety and security is not recommended, due to their different needs throughout the product or service lifetime.

Security measures should not be defined by the publication writers for safety systems, as security is considered to be an own domain within standardization. However, informative references to security publications can be made.

7.4 Specific requirements

7.4.1 Relationship with base security publications

Existing base security publications are listed in [1].

Publication writers should identify particular clauses or subclauses of the applicable base security publications that address their specific security aspects.

7.4.2 Consider conformity assessment when writing standards

Conformity assessment provides the ability to evaluate and assess that specified requirements relating to a product, process, service, person, system or body are fulfilled. Pursuant to Clause 33 of ISO/IEC Directives Part 2:2018, IEC publications should be written in accordance with the "neutrality principle", such that conformity can be assessed by a first party, second party, or third party.

IEC standards that contain requirements should always be developed in such a way that conformity assessment is possible. IEC standards and other normative specifications that do not contain requirements are used to supplement testable standards and are not intended to be used as primary elements in a conformity assessment program

Test security standards that are used for conformity assessment should adhere to the following criteria:

- a) technical requirements should be as technology neutral as possible;
- b) technical requirements should provide the ability to be evaluated, assessed or "tested" in a repeatable and reproducible manner;
- c) technical requirements should avoid "industry accepted" terms unless they denote what is considered industry accepted in a clause of the standard;
- d) technical requirements that require an audit or assessment of an organization or process should provide the expected criteria for assessment.

When any conformity assessment body develops operational documents to manage the ability for third party conformity assessment, it is important that the requirements are developed to remove as much ambiguity or interpretation. Hence, the requirements in the standard should be clear to the user of the standards so the market can develop and design products or processes to meet the requirements found in the standard.

Conformity assessment groups can develop guidance documents for further clarity of the conformity assessment program; however, as illustrated in 5.6.4, it is more effective to deal with guidance and test aspects of a standard through annexes to the main specification rather than by guidance documents from the conformity assessment body.

One other consideration is to reference and/or otherwise utilize the contents of ISO/IEC 17007 [21] suitable for use for conformity assessment.

7.4.3 Lifecycle approach

The threat landscape changes continuously. Stringent security requirements, elaborate security risk assessments and exhaustive security testing during design and development can greatly reduce security risks. Security risks can change due to newly discovered vulnerabilities and changes in the threat landscape.

Security should be considered from the conceptual phase up to and including disposition; this includes the use of secure software development processes, change control/patch management, security monitoring and incident handling throughout the entire lifecycle of the system.

The security management cycle should include ongoing monitoring and remediation, see Figure 7.

A periodical revision of the publication should be considered to address new threats or deprecate old technologies and consider new technologies.

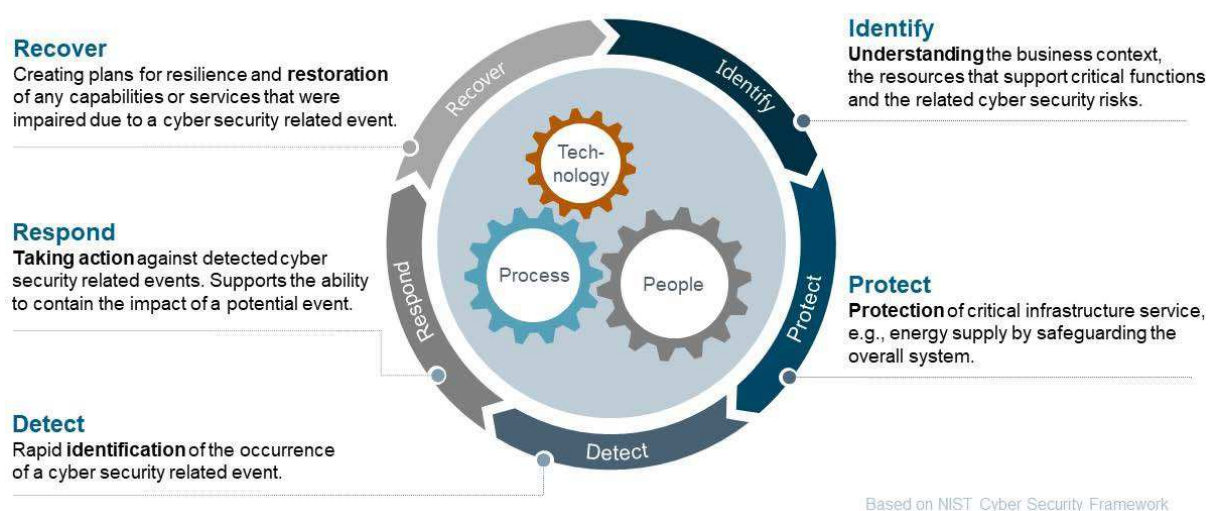


Figure 7 – Example of security management cycle for an organization

7.4.4 Holistic system view

Security should envision the entire environment in which the systems are being used and not in isolation as each interconnected component on a system or in a network architecture could impose a risk to, or rely on the protection of another component on that system or network (e.g. a vulnerability in a mobile app might expose a threat vector to a cloud solution where the backend is hosted).

Security risk assessments should cover both component level and the entire system perspective. The holistic view is needed to identify conflicts, overlaps and gaps, and to ensure complete coverage.

7.4.5 Vulnerability handling

The close cooperation between vendors and their customers, security researchers and national security centres is essential to reveal and appropriately address newly discovered vulnerabilities in released products. The increase of the number of stakeholders involved in complex infrastructures such as cloud applications requires a structured approach towards a coordinated vulnerability management.

Publications should not contain requirements that unnecessarily impede such coordination.

7.4.6 Defence-in-depth

A defence-in-depth security architecture is based on the idea that any one point of protection can, and probably will, be defeated. It implies layers of security and detection, even on single systems.

Security measures are organised in a set of layers, each building a distinct barrier against an attack. These are called lines of defence, see Figure 8.

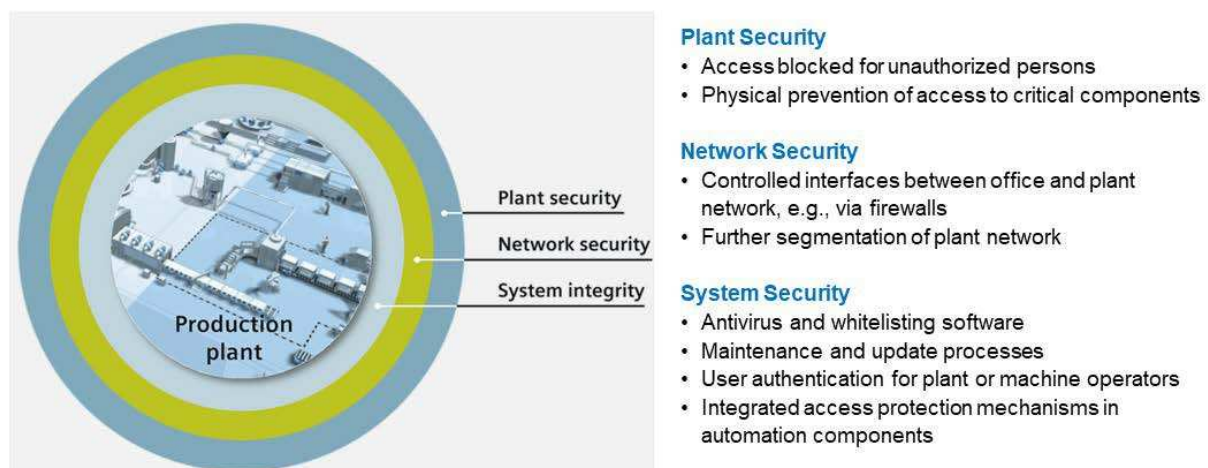


Figure 8 – Selected measures for defence-in-depth strategy

7.4.7 Security management

The security management system preserves the security objectives by applying a risk management process. It provides confidence to interested parties that security risks are adequately managed within the context of the organization.

Regulators may mandate their own generic security framework.

7.4.8 Supply chain

Suppliers can have either a direct or indirect access to the systems of the acquirer, or will provide elements (software, hardware, processes, or human resources) that will be involved in information processing. Acquirers can also have physical and/or logical access to the information of the supplier when they control or monitor production and delivery processes of the supplier.

7.4.9 Consider greenfield and brownfield

7.4.9.1 General

When drafting security-related publications, one has to consider that publication users might face brownfield (existing system) or greenfield (newly designed system) scenarios, which makes a difference in security design needs.

7.4.9.2 Greenfield

In a greenfield scenario, offering a high degree of freedom in engineering a “to-build” plant or system, the major focus will be on security by design. Following such design-based thinking, attention should be given to:

- thorough risk analysis based on experience of comparable plants/systems;
- dimensioning for future upgrades during lifetime operation;
- consideration of expected future requirements;
- remote security monitoring;
- remote software update capabilities.

7.4.9.3 Brownfield

For a brownfield scenario, limiting the publications user and security design engineering to an “as-is” design of an existing plant or system, additional guidance should be given on:

- criteria for the analysis and assessment of existing architectures to address security risks;
- criteria for a conscious “re-use/upgrade or swap/replace” decision;
- identification of limitations when deciding for upgrade/re-use;
- migration aspects for both “upgrade” and “replace” options;
- identification of the remaining risk.

In any case, due to the high dynamics in the security threats, much attention has to be spent to backwards compatibility and future flexibility.

7.4.10 Use of term integrity

The definition of integrity in this document should not be confused with the term integrity used in “safety integrity” (as in IEC 61508 (all parts)) and in dependability publications. This a different property from the one used in functional safety. Publications should clarify which definition they use.

7.5 Security risk assessment

7.5.1 General

Publications for technical system design, implementation and operation should include security risk assessment as a requirement, if appropriate.

Any security risk assessment can be relevant for safety-related applications or non safety-related applications. However, security risk assessment methods are different from those used for safety risk assessment.

The iterative process of security risk assessment and security risk mitigation is essential to achieve or guarantee a defined secure state during the overall lifecycle.

It is necessary to identify the security objectives during the security risk assessment.

Security risk assessment should:

- address the identified security objectives, for example authentication, authorization, accountability, non-repudiation, integrity, confidentiality and availability;
- identify the major threats and failure scenarios for each of the requirements applicable to the document's focus area, including assessing their likelihood and their potential impacts.

As a consequence, security policies and procedures should be developed for all target groups covered in the publication, see 5.5.

Security risk assessment is further explained in IEC/ISO 31010 [20].

7.5.2 Iterative process of security risk assessment and risk mitigation

Publication writers should determine the extent to which the iterative process of security risk assessment and risk mitigation can be included as a requirement within the publication. This might include guidance for the publication user when performing a security risk assessment to identify additional product or system specific risks.

The security risk assessment should use the latest version of the publication, and should be carried out, at least:

- at each lifecycle phase by the designer of a product or system and the end user of this product or system, and
- at regular intervals or whenever triggered (e.g. when new security vulnerabilities become known), to identify new threats and vulnerabilities of the product or system.

Security risk assessment cannot override mandatory requirements for security protection, for example by regulation or customer requirement.

7.5.3 Maintaining safe operation

Maintaining safe operation is one of the overall security objectives of all control systems, see Figure 9.

Security risks will be evaluated by using a security risk assessment in order to identify the security objectives and to derive security measure(s).

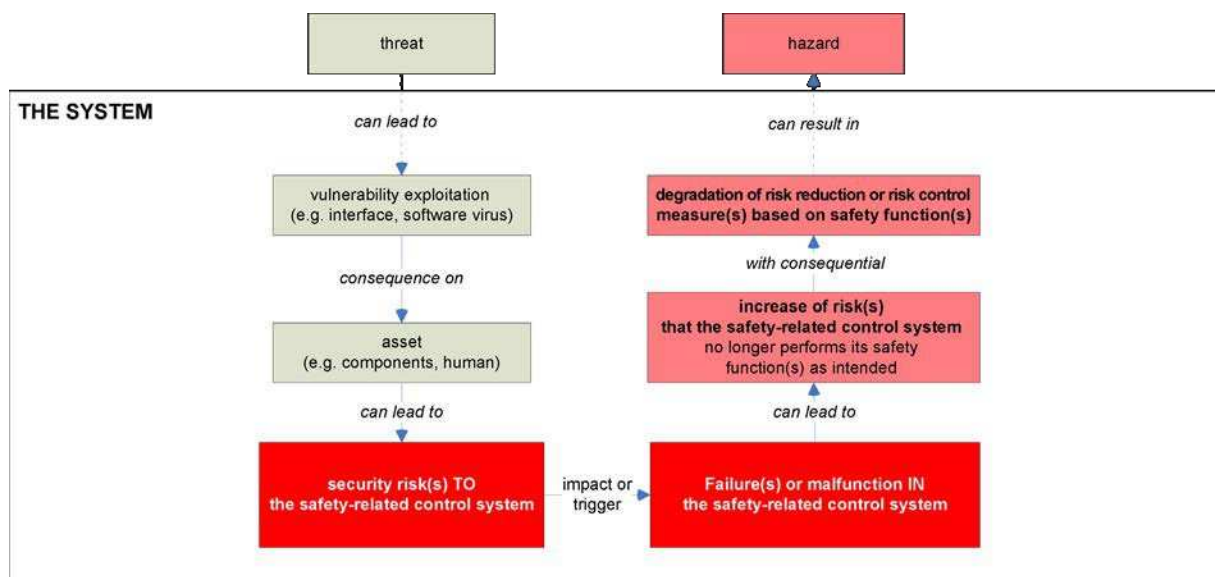


Figure 9 – Possible impact of security risk(s) on the safety-related control system

7.5.4 Scenario analysis

Scenario analysis may be used to develop models of potential threats and identify their associated risk.

Publications incorporating security aspects should provide guidance on scenario analysis where appropriate.

Scenario analysis as defined in IEC/ISO 31010 [20] includes the established techniques of threat modelling.

7.5.5 Security risk mitigation strategy

All products and systems are inherent to some level of security risk. However, the security risk should be reduced to an appropriate secure level.

A security risk mitigation strategy should consider the following options depending on the environment (e.g. location and organization):

- a) design the security risk out (avoid);
- b) reduce the security risk (limit);
- c) accept the security risk;
- d) transfer or share the security risk (to a third entity).

As a consequence, there is a need to define an appropriate secure level, in particular when developments, both in technology and in knowledge, can lead to economically feasible improvements to attain the minimum security risk.

Publications incorporating security aspects should provide guidance on achieving acceptable secure level by an adequate risk mitigation strategy.

7.5.6 Validation

Publications should include guidance to validate the implemented security risk mitigation strategy and security measures including:

- their effectiveness, as well as their testability;
- the security risk assessment strategy (procedure) that has been followed; and
- the documentation of the outcome of the security risk assessment.

Bibliography

- [1] IEC ACSEC dashboard available at <<http://www.iec.ch/acsec>>
- [2] IEC 60050 (all parts), *International Electrotechnical Vocabulary (IEV)*, available at <<http://www.electropedia.org>>
- [3] IEC Glossary. available at <<http://std.iec.ch/glossary>>
- [4] ISO/IEC JTC 1 SC 27, Standing Document SD6, *Glossary of IT Security Terminology*
- [5] INTERNET ENGINEERING TASK FORCE (IETF) RFC 4949: *Internet Security Glossary, Version 2*, available at <<https://tools.ietf.org/html/rfc4949>>
- [6] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST) NISTIR 7298 Revision 2, *Glossary of Key Information Security Terms*, available at <<http://dx.doi.org/10.6028/NIST.IR.7298r2>>
- [7] INSTITUTE OF ELECTRICAL AND ELECTRONICS ENGINEERS (IEEE), *Standards Glossary*, available at <<https://www.standardsuniversity.org/article/standards-glossary/>>
- [8] INTERNATIONAL TELECOMMUNICATION UNION (ITU). *ITU Terms and Definitions*, available at <<https://www.itu.int/ITU-R/go/terminology-database>>
- [9] HEALTH LEVEL SEVEN (HL7), Secure Transactions Special Interest Group. *Glossary Of Acronyms, Abbreviations and Terms Related To Information Security In Healthcare Information Systems*. July 1999, available at <<https://www.hl7.org/documentcenter/public/wg/secure/GLOSSARY2.rtf>>
- [10] INTERNATIONAL ATOMIC ENERGY AGENCY (IAEA), *Nuclear Security Series Glossary*, available at <http://www-ns.iaea.org/security/nuclear_security_series.asp>
- [11] INTERNATIONAL ENERGY AGENCY (IEA). *Glossary*. Available at <<http://www.iea.org/about/glossary/>>
- [12] ISO/IEC 27000:2016, *Information technology – Security techniques – Information security management systems – Overview and vocabulary*
- [13] IEC GUIDE 104:2010, *The preparation of safety publications and the use of basic safety publications and group safety publications*
- [14] IEC GUIDE 108, *Guidelines for ensuring the coherency of IEC publications – Application of horizontal standards*
- [15] ISO/IEC 27001:2013, *Information technology – Security techniques – Information security management systems – Requirements*
- [16] ISO/IEC 27019, *Information technology – Security techniques – Information security management guidelines based on ISO/IEC 27002 for process control systems specific to the energy utility industry*
- [17] IEC 62443-2-1, *Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program*

- [18] IEC 62645, *Nuclear power plants – Instrumentation and control systems – Requirements for security programmes for computer-based systems*
- [19] IEC TS 62351-1:2007, *Power systems management and associated information exchange – Data and communications security – Part 1: Communication network and system security – Introduction to security issues*
- [20] IEC/ISO 31010, *Risk management – Risk assessment techniques*
- [21] ISO/IEC 17007, *Conformity assessment – Guidance for drafting normative documents suitable for use for conformity assessment*
- [22] ISO/IEC 27002, *Information technology – Security techniques – Code of practice for information security controls*
- [23] ISO/IEC 27009, *Information technology – Security techniques – Sector-specific application of ISO/IEC 27001 – Requirements*
- [24] NIST SP 800-53, *Security Controls and Assessment Procedures for Federal Information Systems and Organizations*
- [25] ISO/IEC 27036-1, *Information technology – Security techniques – Information security for supplier relationships – Part 1: Overview and concepts*
- [26] ISO/IEC 27036-2, *Information technology – Security techniques – Information security for supplier relationships – Part 2: Requirements*
- [27] ISO/IEC 27036-3, *Information technology – Security techniques – Information security for supplier relationships – Part 3: Guidelines for information and communication technology supply chain security*
- [28] ISO/IEC 27036-4, *Information technology – Security techniques – Information security for supplier relationships – Part 4: Guidelines for security of cloud services*
- [29] ISO/IEC 29100, *Information technology – Security techniques – Privacy framework*
- [30] ISO/IEC 29101, *Information technology – Security techniques – Privacy architecture framework*
- [31] ISO/IEC 29191, *Information technology – Security techniques – Requirements for partially anonymous, partially unlinkable authentication*
- [32] ISO/IEC 29115, *Information technology – Security techniques – Entity authentication assurance framework*
- [33] ISO/IEC Guide 51:2014, *Safety aspects – Guidelines for their inclusion in standards*
- [34] ISO 31000, *Risk management – Principles and guidelines*
- [35] IEC TS 62443-1-1:2009, *Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models*
- [36] ISO/IEC 24767-1:2008, *Information technology – Home network security – Part 1: Security requirements*

- [37] IEC TS 62351-2:2008, *Power systems management and associated information exchange – Data and communications security – Part 2: Glossary of terms*
 - [38] IEC 62337:2012, *Commissioning of electrical, instrumentation and control systems in the process industry – Specific phases and milestones*
 - [39] IEC TR 62918:2014, *Nuclear power plants – Instrumentation and control important to safety – Use and selection of wireless devices to be integrated in systems important to safety*
 - [40] IEC 61508 (all parts), *Functional safety of electrical/electronic/programmable electronic safety-related systems*
-

INTERNATIONAL
ELECTROTECHNICAL
COMMISSION

3, rue de Varembé
PO Box 131
CH-1211 Geneva 20
Switzerland

Tel: + 41 22 919 02 11
Fax: + 41 22 919 03 00
info@iec.ch
www.iec.ch